FCEFyN

FACULTAD DE CIENCIAS EXACTAS, FÍSICAS Y NATURALES

UNIVERSIDAD NACIONAL DE CÓRDOBA

TRABAJO PRÁCTICO 14

Control de acceso SSH y MFA

Claves, autorización y autenticación multifactor

Cyberseguridad

Estudiante	Brigido Tomas Andres
Legajo	38481096
Carrera	ICOMP
Docente	Javier A. Jorge

Córdoba, Argentina

Índice

1. Introducción y objetivos **2**

2. Acceso SSH mediante claves **2**

2.1. Generación de claves y agente SSH 2

2.2. Conexión inicial y autorización de la clave 3

2.3. Acceso sin contraseña de cuenta y nuevo usuario 4

2.4. Ubicación de claves autorizadas y banner 5

3. Ampliaciones de protección SSH (opcionales) **6**

3.1. Autorización con PAM 6

3.2. Fail2ban 7

3.3. Reflexión 7

4. Autenticación multifactor en SSH **8**

4.1. Preparación del segundo factor 8

4.2. Integración con SSH y PAM 8

4.3. Pruebas de acceso 9

5. Conclusión **10**

6. Referencias **11**

1 Introducción y objetivos

Se configuró el acceso SSH a una VM Debian mediante claves públicas y privadas, autorización con PAM y códigos TOTP. También se evaluó la detección de intentos fallidos con Fail2ban.

2 Acceso SSH mediante claves

2.1 Generación de claves y agente SSH

Se generó un par de claves Ed25519 mediante `ssh-keygen`. La clave privada se guardó como `clave prueba` y la pública como `clave prueba.pub`. Luego se consultó el contenido de la clave pública con `cat`.

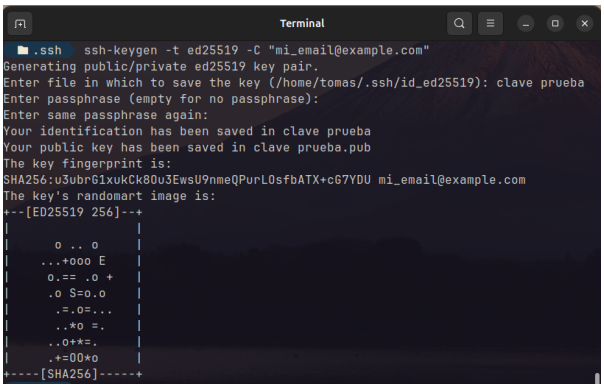


Figura 1: Generación del par de claves Ed25519.

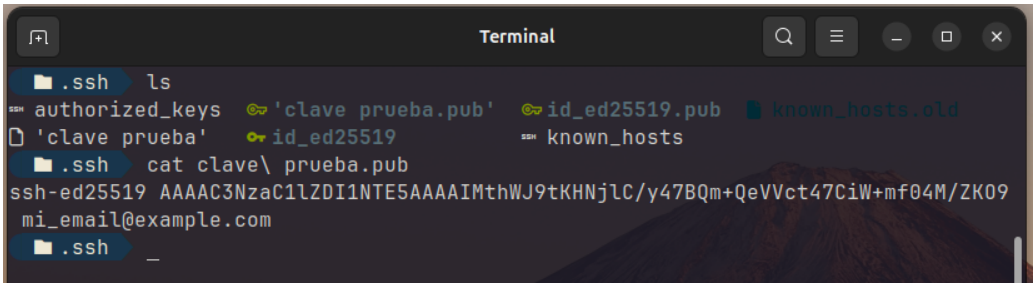


Figura 2: Archivos generados y contenido de la clave pública.

¿Cuáles son los algoritmos que puede utilizar SSH? ¿RSA sigue vigente?

Para autenticación por claves, SSH admite Ed25519, ECDSA y RSA, entre otros. RSA sigue vigente con firmas SHA-2; la variante antigua `ssh-rsa`, que utiliza SHA-1, está deshabilitada por defecto en OpenSSH moderno.

2.2 Conexión inicial y autorización de la clave

Se activó el servidor SSH en la VM y se ingresó con el usuario `osboxes` mediante contraseña. Se utilizó `ssh -p 2222 osboxes@127.0.0.1`, con un reenvío de puertos de VirtualBox desde el puerto 2222 del host hacia el puerto 22 de la VM (`10.0.2.15`).

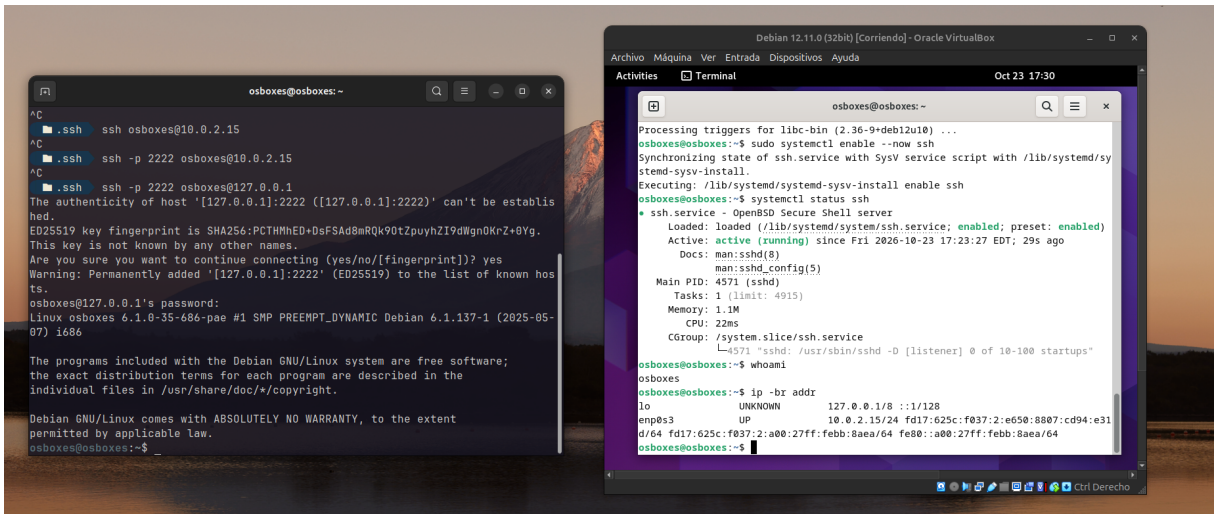


Figura 3: Servidor SSH activo en la VM y conexión desde el host con el usuario osboxes.

¿Puede ingresar con root? ¿Por qué?

No se comprobó el acceso como root: la captura muestra el ingreso como `osboxes`. El acceso de root depende de la configuración del servidor SSH y del método de autenticación permitido.

Se copió la clave pública al servidor mediante `ssh-copy-id` y se comprobó su presencia en `~/.ssh/authorized_keys`. Tras un primer intento con un error del agente SSH, se logró una nueva conexión sin que se solicitara la contraseña del usuario.

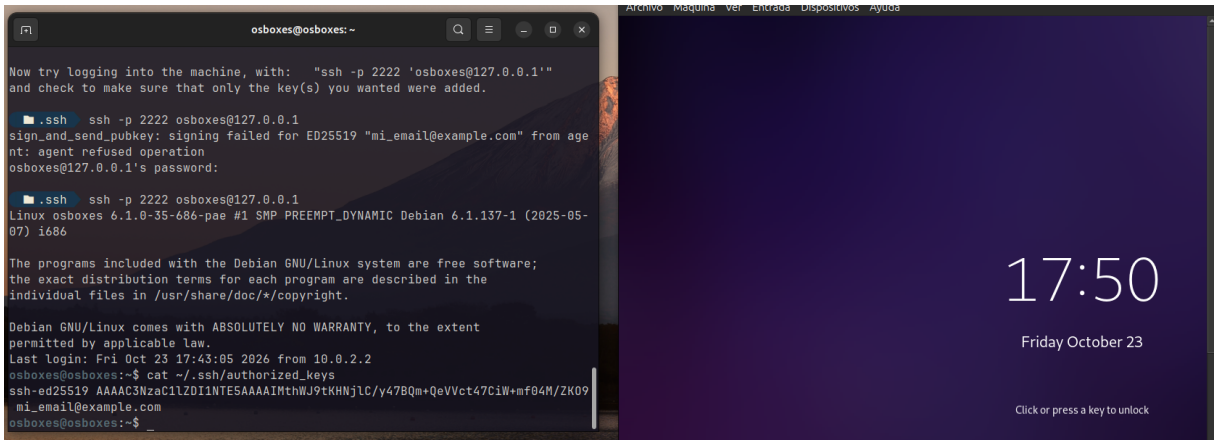


Figura 4: Conexión SSH y comprobación de la clave pública en authorized_keys.

2.3 Acceso sin contraseña de cuenta y nuevo usuario

Se modificó `/etc/ssh/sshd_config` para establecer `PasswordAuthentication no` y deshabilitar la autenticación por contraseña.

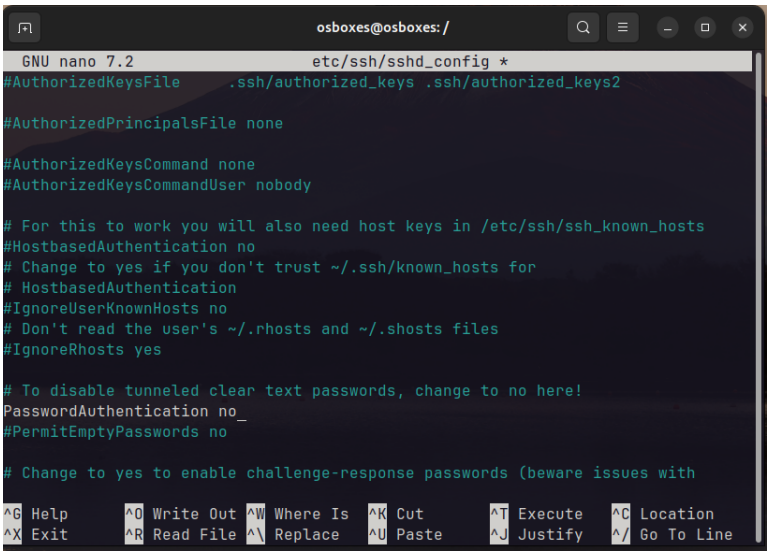


Figura 5: Desactivación de la autenticación por contraseña en SSH.

Se creó el usuario `nopriv` en la VM y se probó el acceso desde el host con `ssh -p 2222 nopriv@127.0.0.1`. El servidor rechazó la conexión por falta de una clave autorizada.

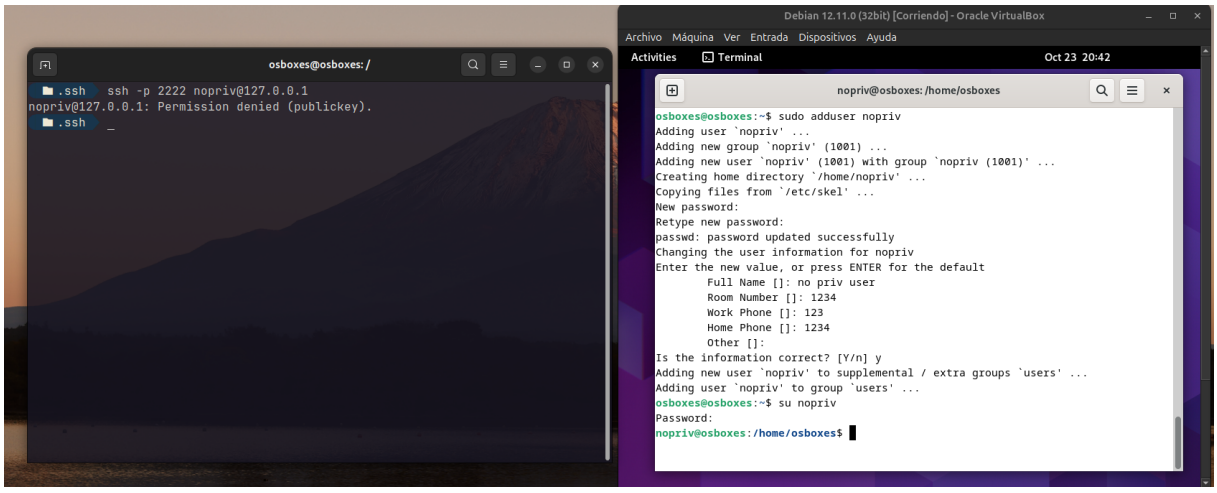


Figura 6: Creación de nopriv y rechazo de su conexión SSH.

¿Puede ingresar? ¿Por qué? ¿Cómo podemos hacer para poder ingresar?

No puede ingresar porque no tiene una clave pública autorizada y el servidor exige autenticación por clave. Para permitir el acceso, se debe agregar nuestra clave pública a `/home/nopriv/.ssh/authorized_keys`, con propietario y permisos adecuados.

2.4 Ubicación de claves autorizadas y banner

`AuthorizedKeysFile` indica dónde busca SSH las claves públicas autorizadas de cada cuenta. En esta práctica se utilizó `~/.ssh/authorized_keys`, sin trasladar las claves a una ubicación centralizada.

Se configuró un banner de bienvenida con un aviso de acceso autorizado. Al iniciar una nueva conexión SSH, se comprobó que el mensaje se muestra correctamente.

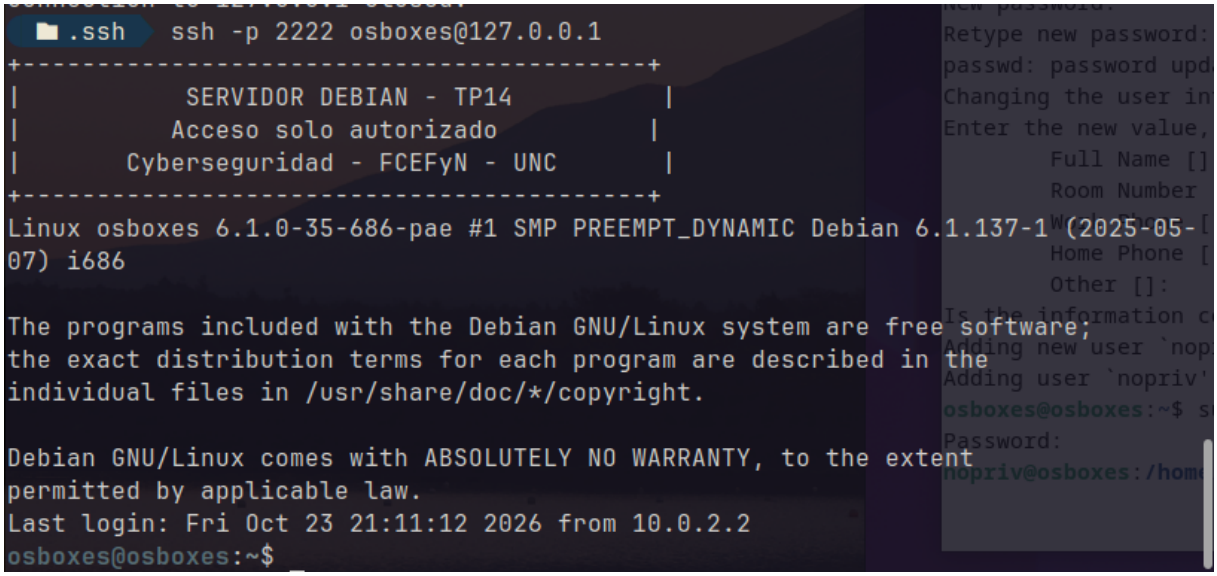


Figura 7: Banner presentado al conectarse por SSH.

3 Ampliaciones de protección SSH (opcionales)

3.1 Autorización con PAM

Se agregó el usuario `osboxes` a `/etc/ssh/ssh.deny` y se configuró PAM con el módulo `pam_listfile` para denegar su acceso. SSH se configuró para exigir clave pública y autenticación interactiva mediante PAM.

La conexión fue rechazada y los registros mostraron `Refused user osboxes for service sshd`, confirmando que PAM bloqueó el acceso de esa cuenta.

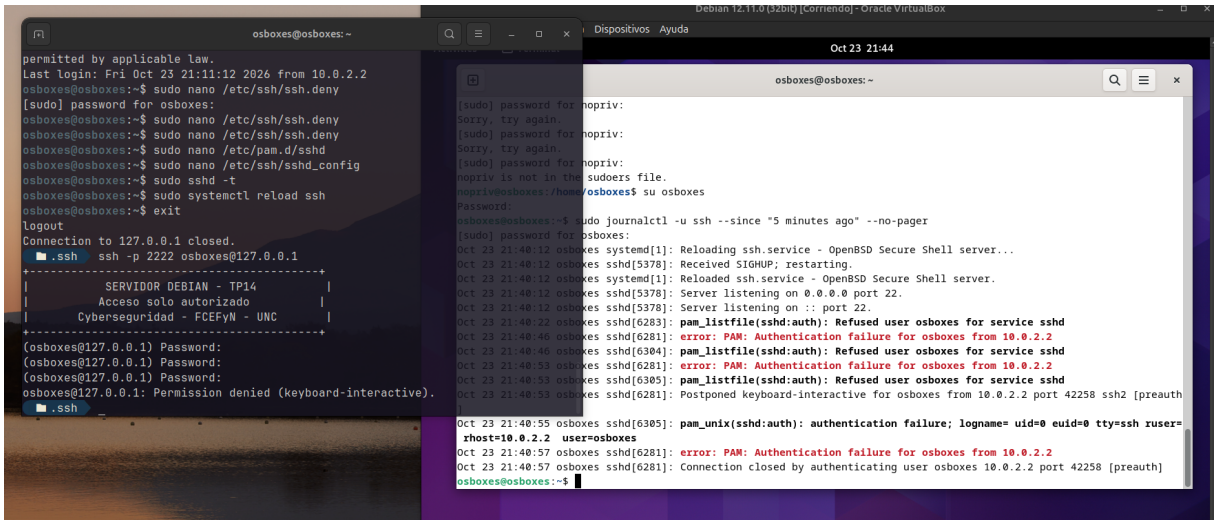


Figura 8: Rechazo de la conexión SSH y registros del bloqueo de osboxes mediante PAM.

3.2 Fail2ban

Se realizaron intentos de acceso SSH con contraseñas incorrectas y se consultó el estado de Fail2ban mediante `sudo fail2ban-client status sshd`.

Intente ingresar con la contraseña equivocada múltiples veces. ¿Qué sucede? ¿Cuál es la salida del comando “sudo iptables -L”?

Fail2ban registró siete fallos y marcó la IP `10.0.2.2` como bloqueada. Sin embargo, luego se pudo ingresar con la contraseña correcta, por lo que no se confirmó un bloqueo efectivo. No se obtuvo la salida de iptables: el comando no fue encontrado.

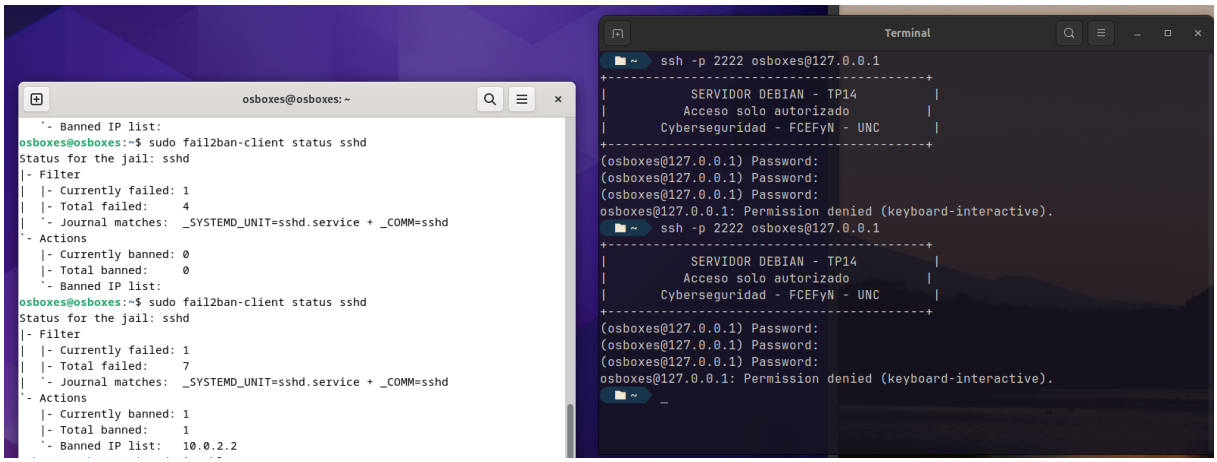


Figura 9: Intentos fallidos e IP marcada como bloqueada por Fail2ban.

3.3 Reflexión

¿En qué casos conviene listar los usuarios a denegar el acceso? ¿Sería más interesante listar solamente a quienes deseo permitir el acceso? ¿En qué casos puede tener sentido?

Una lista de denegados sirve para excluir cuentas puntuales. Una lista de permitidos es conveniente cuando solo un grupo reducido debe acceder, ya que rechaza al resto por defecto.

¿Qué otros servicios puede vigilar Fail2ban? ¿Se puede configurar para que envíe alertas cuando se active?

Puede vigilar servicios como servidores web, FTP y correo, mediante filtros de sus registros. También puede enviar alertas por correo si se configura la acción de notificación y el servicio de envío.

4 Autenticación multifactor en SSH

4.1 Preparación del segundo factor

Se instaló `libpam-google-authenticator` y se ejecutó `google-authenticator` como `osboxes`, sin sudo. Se vinculó la cuenta con Google Authenticator mediante un QR para generar códigos temporales TOTP. Se configuró la prohibición de reutilizar códigos, la ventana temporal predeterminada y la limitación de intentos.

4.2 Integración con SSH y PAM

En `/etc/pam.d/sshd` se comentó `@include common-auth` y se agregó esta regla:

```
auth required pam_google_authenticator.so
```

Así, PAM verifica el código temporal en lugar de la contraseña del usuario. Se retiró a `osboxes` de la lista de denegados para permitir su acceso.

En `/etc/ssh/sshd_config` se mantuvo la siguiente configuración:

```
PubkeyAuthentication yes
PasswordAuthentication no
KbdInteractiveAuthentication yes
UsePAM yes
AuthenticationMethods publickey,keyboard-interactive
```

La conexión exige validar la clave SSH y luego el código TOTP del celular.

4.3 Pruebas de acceso

Al conectarse desde el host, SSH solicitó `Verification code`. Después de ingresar el código del autenticador, se inició la sesión de `osboxes`. No se documentó una prueba con un código TOTP incorrecto.

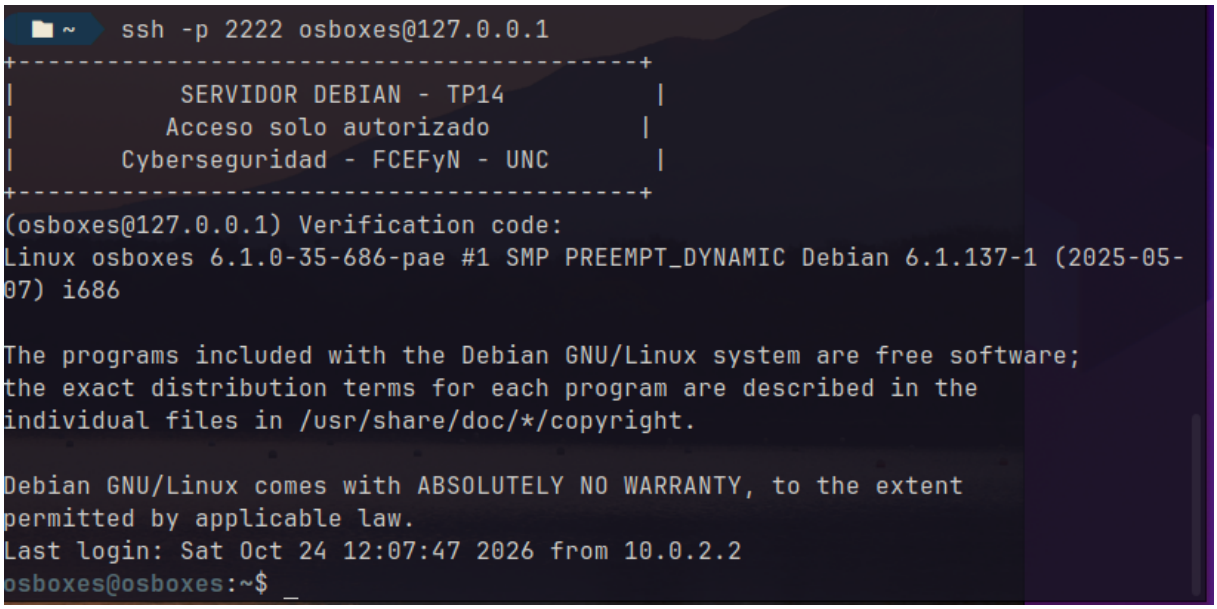


Figura 10: Solicitud del código TOTP e ingreso exitoso a la VM.

5 Conclusión

Se comprobó el acceso por claves, el rechazo de usuarios mediante PAM y el ingreso con clave SSH y código TOTP. Fail2ban detectó fallos y registró una IP bloqueada, aunque no se confirmó la aplicación efectiva del bloqueo en el firewall.

6 Referencias

- *Control de acceso usando SSH y técnicas de protección*. Consigna de laboratorio provista por la cátedra.
- *Multi-factor authentication (MFA)*. Consigna de laboratorio provista por la cátedra.